

University of Essex

CE205
Databases and Information Retrieval

Database Security, Business Intelligence and Machine Learning

Dr. Zulfiqar Ali

Lecturer

School of Computer Science and Electronic Engineering

Most of the slides based on

- *Database Systems: A Practical Approach to Design, Implementation, and Management* by Conoly and Begg, Global Edition/6th Edition.

Recap

You Know

- What are update anomalies
- How to determine FDs in a relation
- What are Armstrong's Axioms for FDs
- What is closure of attributes and how to find Candidate key(s)
- What are different types of FDs, i.e., partial, transitive, full key, and trivial
- What is dependency preserving decomposition
- What is lossless join decomposition
- What is multivalued dependency
- What are 2NF, 3NF, BCNF, 4NF, and 5NF

Learning Objectives

- What is database security
- Various factors involve in security breaches
- What are threats and their different countermeasures
- Application Security
- Business Intelligence
- What is machine learning
    - Supervised Learning
    - Unsupervised Learning

Data

- Data is a valuable resource that must be strictly controlled and managed, as with any corporate resource.



- Part or all the corporate data may have strategic importance and therefore need to be kept secure and confidential.

University of Essex

Database Security

- Mechanisms that protect the database against intentional or accidental threats.

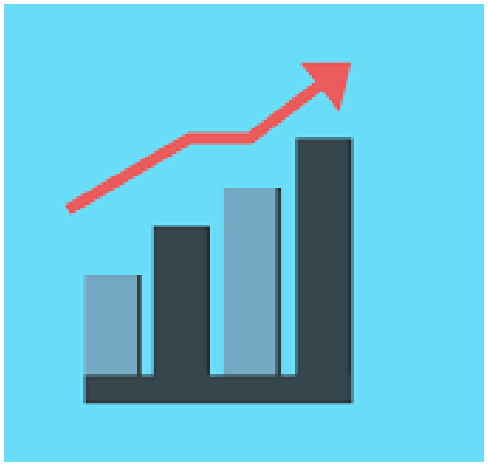


- Developing database security:
  - Determine users' processing rights and responsibilities
  - Enforce security requirements using security features from both DBMS and application programs

- Database security encompasses hardware, software, users, and data.

Growing Trend of Database Security

- Database security is often neglected or overlooked in the past, is now increasingly recognized by organizations.



- The reason for this turnaround is
  - the increasing amounts of crucial corporate data being stored on computer

  and
  - the acceptance that any loss or unavailability of this data could prove to be disastrous.

Security Breaches

Database Security breaches may involves:



- Theft and fraud
- Loss of confidentiality (secrecy)
- Loss of privacy
- Loss of integrity
- Loss of availability

Theft and Fraud

- Theft and fraud affect not only the database environment but also the entire organization.
- Attention should be focused on reducing the opportunities for this occurring.
- Theft and fraud do not necessarily alter data, as is the case for activities that result in either loss of confidentiality or loss of privacy.



Loss of Confidentiality and Privacy

Confidentiality (secrecy)

- Confidentiality refers to the need to maintain secrecy over data—usually only data that is critical to the organization

Privacy

- Privacy refers to the need to protect data about individuals

- **loss of confidentiality** could lead to loss of competitiveness, and
- **loss of privacy** could lead to legal action being taken against the organization.

Loss of Integrity

- Loss of data integrity results in invalid or corrupted data
- It may seriously affect the operation of an organization.
- Many organizations are now seeking virtually continuous operation, the so-called 24/7 availability. If data is invalid or corrupted, such services might be interrupted.

Loss of Availability

- Loss of availability means that the data, or the system, or both cannot be accessed.
- It can seriously affect an organization's financial performance.
- In some cases, events that cause a system to be unavailable may also cause data corruption.

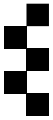
Undetectable Events

- Events such as fraud or loss of privacy
  - may arise because of either intentional or unintentional acts

  and

  - do not necessarily result in any detectable changes to the database or the computer system

Threats and Countermeasures



University of Essex

Threat

- Any situation or event, whether intentional or unintentional, that will adversely affect a system and consequently an organization.
- Any threat must be viewed as a potential breach of security.
- **For example**, **“viewing and disclosing unauthorized data”,** this threat may cause
  - theft and fraud
  - loss of confidentiality
  - and loss of privacy

Some Examples of Threat

THREAT	THEFT AND FRAUD	LOSS OF CONFIDENTIALITY	LOSS OF PRIVACY	LOSS OF INTEGRITY	LOSS OF AVAILABILITY
Using another person's means of access	✓	✓	✓		
Unauthorized amendment or copying of data	✓			✓	
Program alteration	✓			✓	✓
Inadequate policies and procedures that allow a mix of confidential and normal output	✓	✓	✓		

Tangible and Intangible Harm

- A threat may be caused by a situation or event involving a **person**, **action**, or **circumstance** that is likely to bring harm to an organization.
- The harm may be **tangible**, such as loss of hardware, software, or data,
- or **intangible,** such as loss of credibility or client confidence.
- An organization should invest time and effort in identifying the most serious threats.

University of Essex

Suffering Due to Threats

- Suffering of an organization due to threats depends on the existence of countermeasures and contingency plans.
- **For example, if a hardware failure occurs corrupting secondary storage**, all processing activity must cease until the problem is resolved.
- The recovery will depend upon a number of factors:
  - When the last backups were taken
  - The time needed to restore the system.

Countermeasures – Computer-Based Controls

Concerned with physical controls to administrative procedures and includes:

- Authorization and Authentication
- Access controls
- Views
- Backup and recovery
- Integrity
- Encryption
- R A I D technology

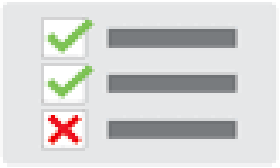
Authorization and Authentication

Authorization

- The granting of a right or privilege, which enables a subject to legitimately have access to a system or a system's object.

Authentication

- Mechanism that determines whether a user is, who he or she claims to be.



Authorization

What you can do



Authentication

Who are you

University of Essex

Access control

- Based on the granting and revoking of privileges.
- A privilege allows a user to create or access (that is read, write, or modify) some database object (such as a relation, view, and tuples) or to run certain DBMS utilities.
- Privileges are granted to users to accomplish the tasks required for their jobs.



Discretionary Access Control (DAC) (1)

- DAC was originally defined by the Trusted Computer System Evaluation Criteria (TCSEC) as “a means of restricting access to objects based on the identity of subjects.
- DAC is identity-based access control.
- The controls are discretionary in the sense that a subject with a certain access permission is capable of passing that permission (perhaps indirectly) on to any other subject (unless restrained by mandatory access control)”.

Discretionary Access Control (DAC) (2)

- SQL standard supports DAC through the GRANT and REVOKE commands.
- The GRANT command gives privileges to users, and the REVOKE command takes away privileges.
- D A C while effective has certain weaknesses. In particular, an unauthorized user can trick an authorized user into disclosing sensitive data.
- An additional approach is required called Mandatory Access Control (MAC).

Mandatory Access Control (MAC)

- MAC based on system-wide policies that cannot be changed by individual users.
  - Each database object is assigned a **security class** and
  - Each user is assigned a **clearance** for a security class
  - **Rules** are imposed on reading and writing of database objects

View (1)

- A database view is a searchable object in a database that is defined by a query.

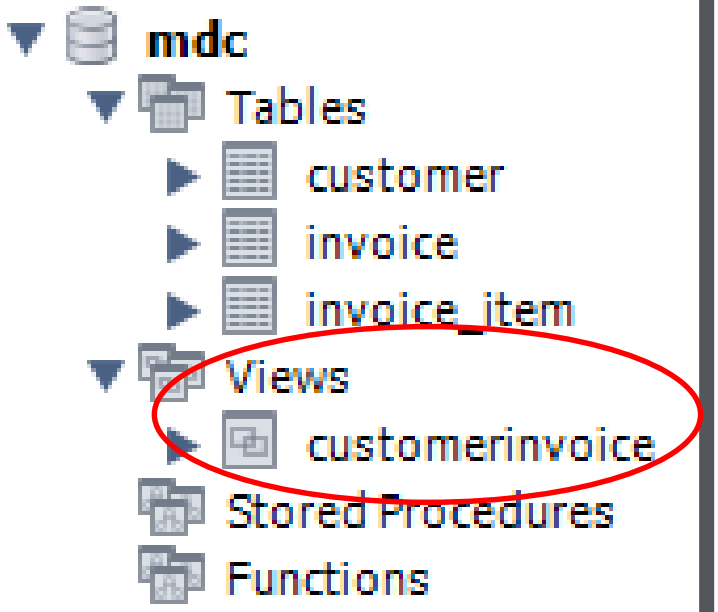
```
CREATE VIEW CustomerInvoice AS

SELECT LastName, FirstName, Phone

FROM CUSTOMER JOIN INVOICE ON
CustomerID=CustomerNumber

WHERE TotalAmount>100

ORDER BY LastName, FirstName DESC;
```



View (2)

- View is the dynamic result of one or more relational operations operating on the base relations to produce another relation.
- A view is a virtual relation that does not actually exist in the database, but is produced upon request by a particular user.

View (3)

- It provides a powerful and flexible security mechanism by hiding parts of the database from certain users.
- The user is not aware of the existence of any attributes or rows that are missing from the view.
- A view can be defined over several relations with a user being granted the appropriate privilege to use it, but not to use the base relations.
- In this way, using a view is more restrictive than simply having certain privileges granted to a user on the base relation(s).

Backup and Recovery (1)

- Process of periodically taking a copy of the database and log file (and possibly programs) to offline storage media.

- In the event of a failure that renders the database unusable, the backup copy and the details captured in the log file are used to restore the database to the latest possible consistent state.

Backup and Recovery (2)

- **Journaling** is a process of keeping and maintaining a log file (or journal) of all changes made to the database to enable effective recovery in the event of failure.

- A DBMS should provide logging facilities, which keep track of the current state of transactions and database changes, to provide support for recovery procedures.

Integrity (1)

- Integrity Constraints prevent data from becoming invalid and avoid misleading or incorrect results.
  - Domain integrity constraint
  - Entity integrity constraint
  - Referential integrity constraint
- The purpose of these three constraints, taken as a whole, is to create database integrity, which means that the data in our database will be useful and meaningful.

Integrity (2)

Domain Integrity Constraint

The requirement that all the values in a column are of the same kind is known as the domain integrity constraint.

Entity Integrity Constraint

The requirement that, in order to function properly, the primary key must have unique data values inserted into every row of the table. This is known as the entity integrity constraint.

Referential Integrity Constraint

A referential integrity constraint is a statement that limits the values of the foreign key to those already existing as primary key values in the corresponding relation

Encryption (1)

- The encoding of the data by a special algorithm that renders the data unreadable by any program without the decryption key.

- If a database system holds particularly sensitive data, it may be deemed necessary to encode it as a precaution against possible external threats or attempts to access it.

Encryption (2) - Cryptosystem

Encoding Process

- an **encryption key** to encrypt the data (*plaintext*);
- an **encryption algorithm** that with the encryption key transforms the *plaintext* into *ciphertext*;

Decoding process

- a **decryption key** to decrypt the *ciphertext*;
- a **decryption algorithm** that with the decryption key transforms the *ciphertext* back into *plaintext*.

Encryption (3) - Cryptosystem

Symmetric Encryption

- uses the same key for both encryption and decryption, and
- relies on safe communication lines for exchanging the key

Asymmetric Encryption

- uses different keys for encryption and decryption

RAID (Redundant Array of Independent Disks) (1)

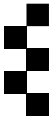
- Hardware that the DBMS is running on must be **fault-tolerant,** meaning that the DBMS should continue to operate even if one of the hardware components fails.

- This suggests having redundant components that can be seamlessly integrated into the working system whenever there is one or more component failures.

RAID (Redundant Array of Independent Disks) (2)

- **Disk drives** are the **most vulnerable** components, and normally have frequent problems as compared to any other hardware components.
- One of the solutions is RAID.
- RAID works on having a large disk array comprising an arrangement of **several independent disks** that are organized to **improve reliability** (*parity scheme or error-correcting scheme*) and at the same time **increase performance** (*data stripping*).

Application Security



University of Essex

Application Security (1)

- Although DBMS products such as Oracle Database, Microsoft SQL Server, and MySQL do provide substantial database security capabilities, those capabilities are generic.
- If the application requires specific security measures, such as ***"No user can view a row of a table or of a join of a table that has an employee's name other than his or her own,"*** the DBMS facilities will not be adequate.
- In these cases, the security system must be augmented by features in database applications.

Application Security (2)

- To understand this better, suppose that an application is written so that when users click a particular button on a browser page
- the following query is sent to the Web server and then to the DBMS:

```
SELECT *
FROM  EMPLOYE;
```

- This statement will return all EMPLOYEE rows.

Application Security (3)

- If the application security policy permits employees to access only their own data, then a Web server could add the following WHERE clause to this query:

```
SELECT *
FROM  EMPLOYEE
WHERE  EMPLOYEE.Name = '<% =
SESSION(("EmployeeName"))%>';
```

- Such expressions will cause the Web server to fill the employee's name into the WHERE clause.

Application Security (4)

- For a user signed in under the name 'Benjamin Franklin', the statement that results from this expression is:

```
SELECT *
FROM  EMPLOYEE
WHERE  EMPLOYEE.Name = 'Benjamin Franklin';
```

- Because the name is inserted by a program on the Web server, the browser user does not know that it is occurring and cannot interfere.

SQL Injection Attack (1)

- Whenever data from the user are used to modify an SQL statement, an SQL injection attack is possible.

- **For example,** if the value of EmployeeName used in the SELECT statement is **not obtained via a secure means**, such as from the operating system rather than from a Web form, there is the chance that the user can inject SQL into the statement.

SQL Injection Attack (2)

- For example, suppose that users are asked to enter their names into a Web form text box. Suppose that a user enters the value 'Benjamin Franklin' OR TRUE for his or her name.
- The SQL statement generated by the application will then be the following:

```
SELECT *
FROM  EMPLOYEE
WHERE  EMPLOYEE.Name = 'Benjamin Franklin' OR TRUE;
```

SQL Injection Attack (3)

- Of course, the value TRUE is true for every row, so every row of the EMPLOYEE table will be returned!

- Thus, any time user input is used to modify an SQL statement, that input must be carefully edited to ensure that only valid input has been received and that no additional SQL syntax has been entered.

Suggested Reading

Database Systems: A Practical Approach to Design, Implementation, and Management by Conoly and Begg, Global Edition/6th Edition.

- Sections: 20.1 and 20.2